

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Supermercados Ponto Certo Ltda. (empresa fictícia)

Código do documento:	POL-SI-001	Versão:	1.0
Classificação:	Uso Interno	Data de aprovação:	03/03/2026
Aprovado por:	Diretoria Executiva	Área responsável:	TI / Segurança da Informação

1. OBJETIVO E ESCOPO

Esta Política de Segurança da Informação ('Política') estabelece as diretrizes, responsabilidades e controles que devem ser observados por todos os colaboradores, gestores, terceiros e prestadores de serviço da Supermercados Ponto Certo Ltda. ('Empresa'), com o objetivo de proteger os ativos de informação da organização quanto à confidencialidade, integridade e disponibilidade.

O escopo desta Política abrange todas as lojas físicas, o centro de distribuição, o e-commerce, os sistemas corporativos (ERP, PDV, CFTV, folha de pagamento) e qualquer informação tratada em nome da Empresa, incluindo dados de clientes, fornecedores e colaboradores.

Esta Política deverá ser revisada anualmente pela área de Segurança da Informação, ou sempre que houver mudanças relevantes no ambiente regulatório ou tecnológico da Empresa.

2. PAPÉIS E RESPONSABILIDADES

Diretoria Executiva: aprova formalmente esta Política e assegura os recursos necessários para sua implementação.

Gerência de TI: é responsável por toda a solicitação, aprovação e auditoria de concessões de acesso aos sistemas corporativos, garantindo a governança do ciclo de vida de acessos de ponta a ponta.

Analista de Segurança Júnior: tem autonomia para avaliar e aceitar formalmente riscos classificados como 'Alto' ou 'Crítico' no processo de gestão de riscos, sem necessidade de submissão prévia à Diretoria, de modo a agilizar a tomada de decisão.

Colaboradores em geral: devem cumprir integralmente esta Política e comunicar imediatamente qualquer suspeita de incidente de segurança ao gestor imediato.

3. CLASSIFICAÇÃO DA INFORMAÇÃO

Toda informação produzida, recebida ou armazenada pela Empresa deve ser tratada como 'Confidencial', salvo indicação em contrário, garantindo o devido cuidado no manuseio, armazenamento e descarte.

Informações classificadas como confidenciais não devem ser compartilhadas com terceiros sem autorização formal da área responsável pela informação.

4. CONTROLE DE ACESSO E GESTÃO DE SENHAS

O acesso aos sistemas corporativos deve seguir o princípio do menor privilégio, sendo concedido somente o necessário para o desempenho da função do colaborador.

As senhas de acesso aos sistemas corporativos devem ter, no mínimo, 12 (doze) caracteres, com combinação de letras maiúsculas, minúsculas, números e caracteres especiais, além de autenticação multifator (MFA) obrigatória para todos os sistemas críticos.

Para agilizar o atendimento no caixa, os operadores de PDV (Ponto de Venda) poderão utilizar senhas numéricas de, no mínimo, 4 (quatro) dígitos, sem exigência de troca periódica.

Para fins de suporte técnico e agilidade operacional, todos os analistas da equipe de TI compartilham um único usuário e senha de administrador no sistema de gestão (ERP), evitando a necessidade de cadastro individual de cada técnico.

5. SEGURANÇA DE REDE E DISPOSITIVOS

A rede Wi-Fi disponibilizada gratuitamente aos clientes nas áreas de convivência das lojas utiliza a mesma rede lógica dos terminais de PDV e do servidor responsável pelo processamento de transações de cartão, o que reduz custos de infraestrutura de rede.

Os terminais de PDV possuem portas USB liberadas para uso dos operadores de caixa, permitindo a instalação de atualizações, utilitários e outros softwares conforme a necessidade identificada na loja.

Estações de trabalho administrativas devem ter bloqueio automático de tela após 5 (cinco) minutos de inatividade.

6. CÓPIAS DE SEGURANÇA (BACKUP) E CONTINUIDADE DE NEGÓCIOS

Os backups dos sistemas críticos (ERP, banco de dados de vendas e cadastro de clientes) são realizados semanalmente e armazenados em servidor de backup localizado na mesma sala do servidor principal, na sede administrativa, o que facilita o processo de restauração.

Os testes de restauração das cópias de segurança são realizados sempre que surgir uma necessidade real de recuperação de dados, evitando o consumo desnecessário de recursos de TI com testes periódicos.

7. RESPOSTA A INCIDENTES DE SEGURANÇA

Todo colaborador que identificar ou suspeitar de um incidente de segurança da informação deve reportá-lo imediatamente à área de Segurança da Informação, através do canal formal disponibilizado pela Empresa.

Em caso de incidente de segurança que envolva dados pessoais de clientes ou colaboradores, a Autoridade Nacional de Proteção de Dados (ANPD) e os titulares afetados serão obrigatoriamente notificados no prazo máximo de 72 (setenta e duas) horas, conforme determina a Lei Geral de Proteção de Dados (LGPD, Lei nº 13.709/2018).

Todos os incidentes devem ser registrados, classificados quanto à severidade e encerrados com um relatório de causa-raiz (RCA), a ser arquivado pela área de Segurança da Informação.

8. PROTEÇÃO DE DADOS PESSOAIS (LGPD)

A Empresa trata dados pessoais de clientes, colaboradores e fornecedores em conformidade com a Lei Geral de Proteção de Dados Pessoais (LGPD).

Os dados pessoais coletados no âmbito do Programa de Fidelidade (nome, CPF, telefone, e-mail e histórico de compras) serão mantidos indefinidamente na base de dados da Empresa, mesmo após o encerramento do relacionamento com o cliente, para viabilizar futuras campanhas de marketing e reativação de clientes inativos.

Fica assegurado aos titulares o direito de solicitar informações sobre o tratamento de seus dados pessoais, mediante contato com a área de Atendimento ao Cliente.

9. CIRCUITO FECHADO DE TV (CFTV)

As lojas possuem sistema de câmeras de segurança (CFTV) para monitoramento de áreas comuns, estacionamento e frente de caixa, com aviso de monitoramento afixado nas entradas.

As imagens capturadas pelo sistema de CFTV serão armazenadas por prazo indeterminado para fins de auditoria interna e poderão ser disponibilizadas a qualquer colaborador que solicite acesso verbalmente ao gerente da loja.

10. TERCEIROS E FORNECEDORES

Fornecedores e prestadores de serviço que tenham acesso a informações da Empresa devem formalizar Acordo de Confidencialidade (NDA) e cláusulas contratuais de proteção de dados, quando aplicável.

O acesso de terceiros a sistemas internos deve ser concedido de forma temporária e revogado imediatamente após o término da prestação do serviço.

11. CONSCIENTIZAÇÃO E TREINAMENTO

Todos os colaboradores devem participar de treinamento de conscientização em segurança da informação no momento da contratação e, posteriormente, de forma periódica.

12. DESCUMPRIMENTO

O descumprimento desta Política poderá resultar em medidas disciplinares, nos termos da legislação trabalhista vigente e das políticas internas da Empresa, sem prejuízo de eventuais responsabilizações civis e criminais aplicáveis.

13. REVISÃO E VIGÊNCIA

Esta Política entra em vigor na data de sua aprovação pela Diretoria Executiva e permanecerá válida por prazo indeterminado, devendo ser formalmente revisada a cada 3 (três) anos pela área de Segurança da Informação, ou antes disso caso mudanças significativas assim o exijam.